| | |
|---|---|
| **Estado** | Finalizado |
| **Comenzado** | martes, 3 de noviembre de 2026, 22:16 |
| **Completado** | martes, 3 de noviembre de 2026, 22:58 |
| **Duración** | 42 minutos 17 segundos |
| **Puntos** | 103,00/103,00 |
| **Calificación** | **10,00** de 10,00 (**100**%) |

**Pregunta 1**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué evidencia mínima confirma un XSS según el criterio del Dossier 04.4?

a. Que el servidor devuelva HTTP 200.
b. Que el texto enviado aparezca en el HTML.
c. Que ZAP asigne riesgo Alto.
d. Que el navegador ejecute el script o se observe un efecto JavaScript verificable.

**Pregunta 2**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué falla existe si un servidor acepta un JWT con algoritmo none y privilegios modificados?

a. El servidor está cifrando demasiado fuerte.
b. El servidor permite tokens sin firma y confía en contenido no autenticado.
c. Existe session fixation.
d. La cookie tiene SameSite=Strict.

**Pregunta 3**

Finalizado

Se puntúa 1,00 sobre 1,00

En ffuf, ¿qué representa normalmente la palabra FUZZ?

a. El nombre de la base de datos.
b. La dirección IP del servidor.
c. El código de estado esperado.
d. La posición de la petición que será reemplazada por cada entrada del diccionario.

**Pregunta 4**

Finalizado

Se puntúa 1,00 sobre 1,00

Una alerta de ZAP tiene riesgo Alto y confianza Baja. ¿Cómo debe interpretarse?

a. Como observación exclusivamente informativa.
b. Como falso positivo confirmado.
c. Como pista importante que requiere validación manual antes de reportarse como hallazgo.
d. Como vulnerabilidad confirmada de severidad alta.

**Pregunta 5**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué describe mejor una vulnerabilidad de mass assignment?

a. El navegador cifra todos los parámetros.
b. El proxy elimina campos ocultos.
c. El backend acepta y asigna campos adicionales enviados por el cliente que no deberían ser modificables.
d. El servidor limita la cantidad de peticiones.

**Pregunta 6**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Cuál de los siguientes conjuntos enumera canales de entrada que deben considerarse potencialmente manipulables?

a. Solo parámetros GET.
b. Únicamente campos de contraseña.
c. Solo archivos JavaScript.
d. Query string, body, cookies y cabeceras HTTP.

**Pregunta 7**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué debe incluir un descarte bien documentado de un falso positivo?

a. Únicamente una captura de pantalla.
b. Solo la conclusión final.
c. Qué se probó, qué respondió el servidor y por qué la evidencia no demuestra explotabilidad.
d. El nombre comercial del escáner.

**Pregunta 8**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Por qué la reproducibilidad es esencial para confirmar un hallazgo?

- a. Porque garantiza que la severidad sea siempre crítica.
- b. Porque reemplaza la necesidad de guardar la request.
- c. Porque permite que otra persona siga los pasos y obtenga consistentemente el mismo resultado.
- d. Porque evita definir controles negativos.

**Pregunta 9**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué diferencia principal existe entre session hijacking y session fixation?

- a. No existe diferencia práctica.
- b. Fixation requiere siempre XSS.
- c. Hijacking solo afecta JWT y fixation solo cookies.
- d. Hijacking roba o reutiliza una sesión ya válida; fixation hace que la víctima use un identificador que el atacante ya conoce antes del login.

**Pregunta 10**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Cuándo resulta especialmente útil AJAX Spider?

- a. Solo en servidores FTP.
- b. En Single Page Applications que construyen gran parte de su contenido con JavaScript.
- c. Únicamente cuando la aplicación devuelve HTTP 404.
- d. En sitios estáticos sin JavaScript.

**Pregunta 11**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué caracteriza al modo Cluster bomb de Intruder?

- a. Usa el mismo payload en todas las posiciones.
- b. Recorre todas las combinaciones posibles entre listas asignadas a distintos puntos.
- c. Solo modifica una posición.
- d. Ejecuta únicamente peticiones GET.

**Pregunta 12**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué archivo utilizaba el Edge antiguo basado en EdgeHTML, según el dossier?

- a. History.sqlite.
- b. cookies.db.
- c. places.sqlite.
- d. WebCacheV01.dat.

**Pregunta 13**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué herramienta de Burp es adecuada para codificar o decodificar Base64, URL, HTML y hexadecimal?

- a. Comparer.
- b. Decoder.
- c. Sequencer.
- d. Scope.

**Pregunta 14**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué atributo obliga a que una cookie se envíe únicamente por HTTPS?

- a. Secure.
- b. SameSite.
- c. Path.
- d. Expires.

**Pregunta 15**

Finalizado

Se puntúa 1,00 sobre 1,00

Para convertir un timestamp Chromium a Unix, ¿qué ajuste se aplica después de dividir por 1000000?

- a. Sumar 11644473600.
- b. Multiplicar por 1601.
- c. Restar 1970.
- d. Restar 11644473600.

**Pregunta 16**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué representa PRTime en Firefox?

- a. Segundos desde 1900.
- b. Microsegundos desde el 1 de enero de 1970.
- c. Milisegundos desde 1601.
- d. Nanosegundos desde 1601.

**Pregunta 17**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué archivo de Edge contiene historial de navegación y descargas?

- a. History.
- b. Web Data.
- c. Login Data.
- d. Cookies.

**Pregunta 18**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Cuál es la función central de OWASP ZAP en el flujo de trabajo presentado?

- a. Actuar como proxy de interceptación y escáner de seguridad web.
- b. Reemplazar el navegador por un servidor web.
- c. Administrar directamente la base de datos del objetivo.
- d. Crear máquinas virtuales vulnerables.

**Pregunta 19**

Finalizado

Se puntúa 1,00 sobre 1,00

Con Intercept off, ¿qué ocurre con el tráfico en Burp?

- a. No atraviesa Burp.
- b. Se envía directamente a Intruder.
- c. Sigue pasando y queda registrado en HTTP history, pero no se detiene para edición.
- d. Se bloquea automáticamente.

**Pregunta 20**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Por qué se dice que HTTP es un protocolo sin memoria?

- a. Porque no puede funcionar sobre TLS.
- b. Porque no soporta cabeceras.
- c. Porque no permite cookies.
- d. Porque cada petición es independiente y el servidor necesita un mecanismo adicional para asociarla a un usuario autenticado.

**Pregunta 21**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué evidencia confirma un Path Traversal?

- a. Un retraso de cinco segundos.
- b. Un cambio de status code.
- c. El contenido de un archivo fuera del directorio previsto aparece en la respuesta.
- d. La aparición de un token de sesión.

**Pregunta 22**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué característica forense importante tiene Edge moderno?

- a. No utiliza SQLite.
- b. No almacena historial localmente.
- c. Usa exclusivamente archivos ESE como WebCacheV01.dat.
- d. Usa una estructura Chromium similar a Chrome.

**Pregunta 23**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Por qué el escaneo activo requiere autorización explícita?

- a. Porque no puede limitarse mediante Scope.
- b. Porque instala software en el servidor.
- c. Porque fabrica y envía peticiones de prueba que pueden alterar datos o afectar el servicio.
- d. Porque solo funciona con credenciales administrativas.

**Pregunta 24**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué archivo contiene los datos de autocompletado de formularios en Firefox?

- a. places.sqlite.
- b. key4.db.
- c. formhistory.sqlite.
- d. favicons.sqlite.

**Pregunta 25**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué función cumple la pestaña Sources o Depurador?

- a. Leer y depurar el JavaScript del frontend, incluyendo puntos de parada.
- b. Administrar certificados TLS del sistema operativo.
- c. Ejecutar escaneos activos contra la aplicación.
- d. Mostrar únicamente cookies de sesión.

**Pregunta 26**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Cómo debería generarse un identificador de sesión seguro según el dossier?

- a. A partir del nombre de usuario y la hora.
- b. Como un número secuencial.
- c. Con un generador criptográficamente seguro y longitud suficiente.
- d. Reutilizando el ID de la sesión anterior.

**Pregunta 27**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué evidencia confirma una SQL Injection con mayor solidez que un mensaje de error?

- a. Un cambio de color en la página.
- b. Una diferencia booleana o temporal reproducible, o extracción de datos.
- c. Una cabecera Server visible.
- d. Un HTTP 500 aislado.

**Pregunta 28**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué diferencia principal tiene un XSS basado en DOM?

- a. El payload necesariamente se almacena en la base de datos.
- b. El flujo vulnerable puede ocurrir completamente en el navegador sin que el payload llegue al servidor.
- c. Solo afecta a navegadores Edge.
- d. Requiere una inyección SQL previa.

**Pregunta 29**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué efecto tiene el modo Protected de ZAP?

- a. Deshabilita todas las peticiones HTTPS.
- b. Limita las acciones de ZAP a las URLs incluidas en el contexto.
- c. Permite escanear cualquier dominio salvo los excluidos manualmente.
- d. Convierte el escaneo activo en pasivo.

**Pregunta 30**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué limitación relevante tiene Burp Community respecto de Professional según el dossier?

- a. No incluye escáner activo automático y limita la velocidad de Intruder.
- b. No incluye Repeater.
- c. No puede trabajar con HTTPS.
- d. No incluye proxy de interceptación.

**Pregunta 31**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Cuál es el orden correcto del ciclo metodológico recomendado en el Dossier 04.1?

- a. Descubrir, autorizar, analizar, mapear, documentar, interceptar, validar.
- b. Mapear, explotar, escanear, documentar, autorizar, validar, cerrar.
- c. Validar, autorizar, documentar, mapear, interceptar, descubrir, analizar.
- d. Autorizar, mapear, descubrir, interceptar, analizar, validar, documentar.

**Pregunta 32**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Cuál es la diferencia conceptual entre descubrimiento de contenido y fuzzing?

- a. Son sinónimos exactos.
- b. El fuzzing solo sirve para explotar vulnerabilidades confirmadas.
- c. El descubrimiento requiere necesariamente acceso al código fuente.
- d. El descubrimiento es el objetivo de encontrar recursos no enlazados y el fuzzing es una técnica para probar muchas variantes de entrada.

**Pregunta 33**

Finalizado

Se puntúa 1,00 sobre 1,00

En una evaluación web, ¿qué afirmación describe mejor la diferencia entre un escaneo automático y un pentest web?

- a. El pentest web valida de manera controlada si una debilidad puede producir impacto y documenta evidencia reproducible.
- b. El pentest web se limita a revisar versiones de software.
- c. El escaneo automático reemplaza la necesidad de definir alcance.
- d. El escaneo automático siempre confirma el impacto de una vulnerabilidad.

**Pregunta 34**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué lista mencionada en el dossier está orientada específicamente a nombres de parámetros comunes?

- a. burp-parameter-names.txt.
- b. raft-large-files.txt.
- c. subdomains-top1million-5000.txt.
- d. common-passwords.txt.

**Pregunta 35**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué indica normalmente un código HTTP 403 durante descubrimiento de contenido?

- a. Que el recurso existe pero el acceso está prohibido.
- b. Que existe una SQL Injection.
- c. Que el recurso no existe.
- d. Que el servidor redirige a otra ruta.

**Pregunta 36**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué herramienta se destaca en el dossier por la recursión automática sobre directorios descubiertos?

a. sqlmap.
b. nmap.
c. sqlite3.
d. feroxbuster.

**Pregunta 37**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué representa [INFO] en la clasificación propuesta?

a. Un hallazgo confirmado con riesgo bajo.
b. Una observación sin impacto demostrado al nivel de severidad actual, útil como hardening o contexto.
c. Una vulnerabilidad crítica no explotada.
d. Un exploit fallido.

**Pregunta 38**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Por qué conviene definir el Scope antes de comenzar una sesión de Burp?

a. Para filtrar y limitar el trabajo al dominio autorizado y evitar actuar sobre terceros.
b. Para deshabilitar HTTPS.
c. Para aumentar el número de peticiones.
d. Para modificar automáticamente cookies.

**Pregunta 39**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué problema resuelve el filtro -fs de ffuf?

a. Oculta respuestas que tienen un tamaño determinado, útil para eliminar páginas de error repetitivas.
b. Cambia el método HTTP.
c. Agrega extensiones a cada palabra.
d. Limita el fuzzing a HTTPS.

**Pregunta 40**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Cuál es la defensa principal contra SQL Injection indicada en el dossier?

- a. Utilizar consultas parametrizadas o prepared statements.
- b. Ocultar los mensajes de error únicamente.
- c. Cambiar el método POST por GET.
- d. Codificar la entrada en Base64.

**Pregunta 41**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué tablas de places.sqlite son relevantes para historial y visitas?

- a. urls y visits.
- b. moz_places y moz_historyvisits.
- c. autofill y credit_cards.
- d. cookies y logins.

**Pregunta 42**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Para qué se utiliza Comparer?

- a. Para gestionar sesiones del sistema operativo.
- b. Para descubrir subdominios.
- c. Para importar certificados.
- d. Para comparar dos peticiones o respuestas y resaltar diferencias.

**Pregunta 43**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Por qué los valores de cookies y contraseñas de Edge pueden aparecer como blobs ilegibles?

- a. Porque están cifrados mediante DPAPI asociado al contexto del usuario de Windows.
- b. Porque están codificados únicamente en Base64.
- c. Porque están comprimidos con ZIP.
- d. Porque usan PRTime.

**Pregunta 44**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué herramienta mencionada está orientada específicamente al análisis de navegadores Chromium y puede reunir múltiples artefactos en una línea de tiempo?

- a. dumpzilla.
- b. Hindsight.
- c. ffuf.
- d. sqlmap.

**Pregunta 45**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Cuál es la finalidad de un Contexto en ZAP?

- a. Modificar automáticamente la base de datos.
- b. Crear un diccionario de contraseñas.
- c. Cambiar la versión de Java.
- d. Definir qué URLs forman parte de la aplicación analizada y limitar el trabajo al alcance autorizado.

**Pregunta 46**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Por qué un escáner puede reportar XSS cuando solo observa que el payload aparece reflejado en la respuesta?

- a. Porque toda reflexión es automáticamente XSS.
- b. Porque los escáneres evalúan siempre la ejecución de JavaScript.
- c. Porque HTTP 200 confirma ejecución en el navegador.
- d. Porque una coincidencia de patrón puede confundir reflexión con ejecución real.

**Pregunta 47**

Finalizado

Se puntúa 1,00 sobre 1,00

Si document.cookie no muestra la cookie de sesión, ¿qué atributo puede explicar ese comportamiento?

- a. SameSite=None.
- b. Secure.
- c. Domain.
- d. HttpOnly.

**Pregunta 48**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Cuál de los siguientes elementos forma parte de la superficie de ataque de una aplicación web según el Dossier 04.1?

a. Únicamente los puertos TCP abiertos del servidor.
b. Exclusivamente los formularios que requieren autenticación.
c. Solo las páginas visibles desde el menú principal.
d. URLs, parámetros, cabeceras, cookies, archivos, APIs, WebSockets e integraciones.

**Pregunta 49**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué ventaja ofrece la opción Copiar como cURL sobre una petición observada en DevTools?

a. Permite repetir desde terminal una petición completa conservando sus principales componentes.
b. Oculta los parámetros sensibles de la petición.
c. Convierte automáticamente la petición en un exploit.
d. Sustituye al proxy HTTPS.

**Pregunta 50**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué diferencia principal existe entre el Spider tradicional y AJAX Spider?

a. El Spider tradicional ejecuta JavaScript y AJAX Spider no.
b. AJAX Spider usa un navegador real y ejecuta JavaScript, mientras el tradicional sigue enlaces y formularios del HTML.
c. AJAX Spider no descubre rutas dinámicas.
d. El Spider tradicional solo funciona sobre HTTPS.

**Pregunta 51**

Finalizado

Se puntúa 1,00 sobre 1,00

En Intruder, ¿qué modo prueba una sola lista sobre un punto de inyección por vez?

a. Pitchfork.
b. Cluster bomb.
c. Sniper.
d. Battering ram.

**Pregunta 52**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Cuál de las siguientes situaciones representa un criterio profesional de análisis correcto?

- a. Presentar automáticamente como hallazgo cualquier alerta generada por una herramienta.
- b. Verificar si el comportamiento es reproducible y si el impacto demostrado justifica la severidad propuesta.
- c. Reportar toda cabecera ausente como vulnerabilidad crítica.
- d. Asignar severidad según la clase teórica sin considerar el contexto.

**Pregunta 53**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Dónde se encuentra normalmente el perfil Default de Microsoft Edge actual en Windows?

- a. %LOCALAPPDATA%\Microsoft\Edge\User Data\Default\
- b. %TEMP%\Edge\History\
- c. %APPDATA%\Mozilla\Firefox\Profiles\
- d. C:\Program Files\Edge\Default\

**Pregunta 54**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué caracteriza al escaneo pasivo de ZAP?

- a. Modifica formularios para buscar fallas.
- b. Requiere autorización para cada cabecera que analiza.
- c. Genera payloads de SQLi y XSS.
- d. Observa el tráfico ya existente sin enviar nuevas peticiones al servidor.

**Pregunta 55**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Por qué debe importarse la CA raíz de ZAP en el navegador de laboratorio?

- a. Para cambiar el dominio de la aplicación.
- b. Para que ZAP pueda emitir certificados dinámicos confiables para interceptar HTTPS.
- c. Para impedir que el servidor use TLS.
- d. Para firmar los archivos descargados por el usuario.

**Pregunta 56**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué diferencia temporal fundamental existe entre Edge/Chrome y Firefox?

- a. Ambos usan exactamente el mismo epoch.
- b. Firefox usa segundos desde 1601 y Chromium segundos desde 1970.
- c. Edge no guarda timestamps.
- d. Chromium usa microsegundos desde 1601 y Firefox PRTime usa microsegundos desde 1970.

**Pregunta 57**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué analiza Sequencer?

- a. Los permisos de una base de datos.
- b. La velocidad de descarga de archivos.
- c. La aleatoriedad y predictibilidad de tokens de sesión.
- d. La estructura del DOM.

**Pregunta 58**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Cuál es el epoch utilizado por timestamps de Chromium según el dossier?

- a. Segundos desde 1 de enero de 2000.
- b. Microsegundos desde 1 de enero de 1601.
- c. Microsegundos desde 1 de enero de 1970.
- d. Milisegundos desde 1 de enero de 1900.

**Pregunta 59**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Dónde se encuentra normalmente el perfil de Firefox en Windows?

- a. C:\Windows\System32\Firefox\
- b. %APPDATA%\Mozilla\Firefox\Profiles\
- c. %TEMP%\Firefox\History\
- d. %LOCALAPPDATA%\Microsoft\Edge\User Data\Default\

**Pregunta 60**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué archivo de Firefox contiene principalmente historial de navegación y marcadores?

- a. key4.db.
- b. formhistory.sqlite.
- c. places.sqlite.
- d. cookies.sqlite.

**Pregunta 61**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué caracteriza a una SQLi temporal ciega?

- a. Devuelve siempre los datos directamente en pantalla.
- b. Usa el tiempo de respuesta como canal de información y requiere comparar demoras reproducibles.
- c. Requiere modificar cookies del navegador.
- d. Solo funciona si existe XSS.

**Pregunta 62**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Cuál es la mitigación principal contra session fixation?

- a. Regenerar el identificador de sesión al autenticarse.
- b. Guardar el ID en la URL.
- c. Desactivar HTTPS.
- d. Conservar el mismo ID antes y después del login.

**Pregunta 63**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Cuál es el primer paso de la metodología de validación manual propuesta?

- a. Reproducir manualmente el comportamiento reportado.
- b. Publicar el hallazgo.
- c. Asignar severidad.
- d. Ejecutar un escaneo más agresivo.

**Pregunta 64**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Cuál es la función principal de SameSite?

- a. Ocultar la cookie al servidor.
- b. Cifrar el contenido de la cookie.
- c. Controlar si la cookie se envía en peticiones iniciadas desde otro sitio y reducir riesgo de CSRF.
- d. Definir la longitud del identificador de sesión.

**Pregunta 65**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué almacén del navegador está diseñado para conservar datos hasta que se cierre la pestaña o sesión correspondiente?

- a. Cache-Control.
- b. localStorage.
- c. IndexedDB.
- d. sessionStorage.

**Pregunta 66**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué práctica fortalece la cadena de custodia de un perfil de Firefox?

- a. Editar las bases para corregir timestamps.
- b. Eliminar los archivos auxiliares antes de analizarlos.
- c. Documentar origen, fecha de adquisición y calcular un hash de la copia.
- d. Abrir el perfil con Firefox mientras se analiza.

**Pregunta 67**

Finalizado

Se puntúa 1,00 sobre 1,00

Durante una enumeración, un endpoint devuelve HTTP 403. ¿Cuál es la interpretación más adecuada?

- a. El recurso existe, pero el acceso está prohibido para el contexto actual.
- b. El recurso necesariamente no existe.
- c. La aplicación confirmó una inyección SQL.
- d. El servidor está caído.

**Pregunta 68**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué diferencia establece el Dossier 04.1 entre descubrimiento, escaneo y enumeración?

a. El descubrimiento explota, el escaneo documenta y la enumeración corrige.
b. Son sinónimos y producen el mismo resultado.
c. El descubrimiento busca qué existe, el escaneo observa cómo responde y la enumeración extrae información específica de esas respuestas.
d. La enumeración solo aplica a infraestructura y no a web.

**Pregunta 69**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué operación es necesaria para convertir PRTime a segundos Unix?

a. Multiplicar por 1000000.
b. Dividir por 1601.
c. Dividir por 1000000.
d. Restar 11644473600.

**Pregunta 70**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Cuál de las siguientes evidencias es la más adecuada para sostener profesionalmente un hallazgo web?

a. Request completa, response relevante, fecha/hora, objetivo, herramienta y pasos de validación.
b. Solo el código HTTP devuelto.
c. Una captura aislada del navegador sin contexto.
d. La severidad asignada por un escáner.

**Pregunta 71**

Finalizado

Se puntúa 1,00 sobre 1,00

Un sitio devuelve HTTP 200 para todas las rutas inexistentes, siempre con 1234 bytes. ¿Qué estrategia es la más adecuada?

a. Detener el análisis porque el servidor no usa 404.
b. Filtrar únicamente HTTP 404.
c. Ejecutar ffuf filtrando el tamaño 1234 con -fs 1234.
d. Considerar todas las respuestas como válidas.

**Pregunta 72**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué dimensión de análisis se ocupa de revisar cookies, cabeceras de seguridad, CORS y CSP?

- a. Configuración.
- b. Monitoreo.
- c. Identidad.
- d. Exposición.

**Pregunta 73**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué ventaja ofrece Manual Explore frente a Automated Scan?

- a. Ejecuta más rápido todos los ataques.
- b. Garantiza que todas las alertas sean confirmadas.
- c. Da mayor control al operador y reduce ruido y falsos positivos al decidir qué atacar.
- d. Deshabilita el proxy y trabaja fuera de HTTP.

**Pregunta 74**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué atributo de cookie impide que JavaScript pueda leer su valor mediante document.cookie?

- a. Domain.
- b. Secure.
- c. Max-Age.
- d. HttpOnly.

**Pregunta 75**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Cuándo corresponde clasificar un hallazgo como [CONFIRMED]?

- a. Cuando el impacto está demostrado, es reproducible y la evidencia fue preservada.
- b. Cuando el operador considera probable la vulnerabilidad.
- c. Cuando el escáner lo marca como rojo.
- d. Cuando existe una respuesta HTTP diferente.

**Pregunta 76**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Por qué se recomienda trabajar sobre una copia de las bases SQLite del perfil?

- a. Para eliminar la necesidad de hashes.
- b. Porque las consultas nunca pueden leer el original.
- c. Porque sqlite3 exige archivos renombrados.
- d. Para preservar la evidencia original y evitar modificaciones o corrupción.

**Pregunta 77**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué puede revelar el Inspector/Elements que no siempre es visible en la interfaz gráfica?

- a. Consultas SQL ejecutadas por el backend.
- b. Campos hidden, botones deshabilitados y estructura HTML renderizada.
- c. Claves privadas del servidor TLS.
- d. Tablas de la base de datos remota.

**Pregunta 78**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Cuál es la función principal de Burp Repeater?

- a. Medir la entropía de tokens.
- b. Repetir y editar manualmente una misma petición para comparar respuestas.
- c. Administrar certificados del servidor.
- d. Ejecutar automáticamente miles de combinaciones.

**Pregunta 79**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Por qué conviene activar Preserve log antes de ejecutar una secuencia de navegación que cambia de página?

- a. Para impedir que se borre el registro de peticiones al navegar.
- b. Para cifrar las cookies.
- c. Para bloquear JavaScript.
- d. Para enviar automáticamente las peticiones a Burp.

**Pregunta 80**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Cuándo una repetición de una petición copiada desde DevTools deja de ser una mera observación y pasa a ser una prueba activa?

a. Cuando se lee el HTML.
b. Cuando se inspecciona una cookie sin modificarla.
c. Cuando se abre la pestaña Network.
d. Cuando se cambia algún parámetro y se reenvía al servidor.

**Pregunta 81**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Cuál de las siguientes tareas corresponde a fuzzing de parámetros?

a. Usar https://sitio/FUZZ para descubrir directorios.
b. Consultar tablas SQLite del navegador.
c. Cambiar únicamente el User-Agent a mano.
d. Usar ?FUZZ=1 para descubrir nombres de parámetros aceptados por el backend.

**Pregunta 82**

Finalizado

Se puntúa 1,00 sobre 1,00

Un analista quiere buscar claves de API o endpoints internos olvidados en el frontend. ¿Dónde debería comenzar?

a. En el certificado del servidor únicamente.
b. En los archivos JavaScript accesibles desde Sources y buscando términos como apiKey, token o secret.
c. En la tabla ARP de la red.
d. En el registro de eventos de Windows.

**Pregunta 83**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Cuál de las siguientes situaciones confirma un XSS según el dossier?

a. El servidor devuelve una cabecera CSP.
b. El navegador ejecuta JavaScript controlado por el evaluador.
c. El payload aparece como texto plano en la respuesta.
d. La petición devuelve HTTP 200.

**Pregunta 84**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Por qué una validación realizada únicamente en JavaScript del navegador no debe considerarse un control de seguridad suficiente?

- a. Porque JavaScript no puede leer respuestas HTTP.
- b. Porque JavaScript solo funciona sobre HTTP y no sobre HTTPS.
- c. Porque el backend ignora siempre los datos enviados por el navegador.
- d. Porque el usuario controla el navegador y puede modificar o desactivar esa validación.

**Pregunta 85**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Cuáles son las tres partes de un JWT?

- a. header.payload.signature.
- b. key.iv.ciphertext.
- c. method.path.body.
- d. usuario.sesion.cookie.

**Pregunta 86**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué relación existe entre logins.json y key4.db?

- a. logins.json contiene credenciales cifradas y key4.db contiene material necesario para descifrarlas.
- b. key4.db contiene el historial y logins.json las cookies.
- c. Ambos contienen exactamente la misma información.
- d. Ninguno está relacionado con credenciales.

**Pregunta 87**

Finalizado

Se puntúa 1,00 sobre 1,00

En DevTools, ¿qué pestaña es la principal para observar URL, método, cabeceras, cuerpo y respuesta de cada petición?

- a. Elements.
- b. Network.
- c. Sources.
- d. Console.

**Pregunta 88**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué tablas del archivo History son relevantes para historial, visitas y descargas?

- a. urls, visits y downloads.
- b. cookies, logins y autofill.
- c. top_sites, credit_cards y shortcuts.
- d. moz_places, moz_historyvisits y moz_annos.

**Pregunta 89**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué confirma una Command Injection en un caso no ciego?

- a. La ruta devuelve HTTP 403.
- b. El HTML refleja el parámetro sin ejecutarlo.
- c. Se observa una cookie sin Secure.
- d. La salida de un comando del sistema controlado aparece en la respuesta.

**Pregunta 90**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué afirmación sobre el contenido de un JWT es correcta según el dossier?

- a. La firma contiene siempre la contraseña del usuario.
- b. Header y payload suelen estar codificados y pueden leerse; la firma protege su integridad.
- c. Header y payload están cifrados por defecto.
- d. Un JWT no puede incluir expiración.

**Pregunta 91**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué demuestra que un logout es defectuoso del lado del servidor?

- a. Una cookie capturada antes del logout sigue siendo aceptada para acceder como usuario autenticado.
- b. La aplicación redirige al login.
- c. La página devuelve HTTP 302.
- d. La cookie desaparece visualmente del navegador.

**Pregunta 92**

Finalizado

Se puntúa 1,00 sobre 1,00

Un operador descubre un subdominio que no figura en el alcance autorizado. ¿Cuál es la acción correcta?

a. Incluirlo automáticamente porque pertenece al mismo dominio raíz.
b. Probar solo el puerto 443 y detenerse si responde.
c. Escanearlo pasivamente porque fue descubierto durante la evaluación.
d. Considerarlo fuera de alcance hasta recibir autorización explícita.

**Pregunta 93**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Cuál es la idea común que explica gran parte de las vulnerabilidades de inyección?

a. Toda entrada GET es segura.
b. Solo los formularios visibles pueden ser manipulados.
c. Un dato controlado por el usuario cruza hacia un intérprete y se mezcla con sintaxis ejecutable.
d. El usuario controla exclusivamente el servidor.

**Pregunta 94**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué significa aislar la variable durante una validación?

a. Probar el hallazgo desde otra organización.
b. Cambiar varios parámetros a la vez para acelerar el análisis.
c. Modificar un solo parámetro por vez y compararlo con un control positivo o negativo.
d. Eliminar la request original.

**Pregunta 95**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Por qué la calidad de la wordlist afecta directamente el resultado del fuzzing?

a. Porque modifica la respuesta del servidor.
b. Porque reemplaza los filtros HTTP.
c. Porque la wordlist define el algoritmo TLS.
d. Porque la herramienta solo probará los valores incluidos en esa lista.

**Pregunta 96**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Cuándo corresponde mantener una observación como [POSSIBLE]?

- a. Cuando existe comportamiento anómalo pero todavía no se alcanzó el estándar de evidencia.
- b. Cuando la vulnerabilidad fue corregida.
- c. Cuando no existe ningún indicio.
- d. Cuando el impacto está completamente demostrado.

**Pregunta 97**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Por qué un HTTP 301 o 302 puede ser una pista valiosa durante fuzzing de rutas?

- a. Porque confirma que la base de datos está accesible.
- b. Porque suele indicar que existe un recurso o directorio que redirige a su ruta canónica.
- c. Porque siempre revela credenciales.
- d. Porque demuestra un XSS.

**Pregunta 98**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué hace una regla Match and Replace en Burp?

- a. Compara hashes de archivos.
- b. Crea nuevas sesiones de usuario.
- c. Sustituye automáticamente patrones en peticiones o respuestas que pasan por el proxy.
- d. Ejecuta escaneos de red.

**Pregunta 99**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué archivo de Edge contiene credenciales guardadas?

- a. Top Sites.
- b. History.
- c. Shortcuts.
- d. Login Data.

**Pregunta 100**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué evidencia confirma un IDOR de forma limpia?

a. Que el identificador sea numérico.
b. Que la URL contenga un parámetro id.
c. Que, autenticado como una cuenta de prueba A, se obtengan datos pertenecientes a otra cuenta de prueba B.
d. Que el endpoint devuelva 200 con el recurso propio.

**Pregunta 101**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Por qué places.sqlite es especialmente valioso en el análisis presentado?

a. Porque contiene la clave maestra del sistema operativo.
b. Porque contiene exclusivamente contraseñas.
c. Porque además del historial puede registrar información relacionada con descargas.
d. Porque cifra todas las cookies.

**Pregunta 102**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Qué evidencia diferencia una SQLi booleana ciega de una simple respuesta errática?

a. Un token JWT válido.
b. Un único HTTP 500.
c. Una diferencia consistente y repetible entre una condición verdadera y una falsa.
d. La presencia de JavaScript en la página.

**Pregunta 103**

Finalizado

Se puntúa 1,00 sobre 1,00

¿Cuál es el principal riesgo señalado en el dossier al almacenar un token de sesión en localStorage?

a. No puede ser enviado por HTTPS.
b. Solo puede ser usado por extensiones del navegador.
c. Cualquier JavaScript ejecutado en la página puede leerlo, incluido código inyectado mediante XSS.
d. El navegador lo elimina al cerrar la pestaña.